

SIMATS ENGINEERING

ASSESSMENT TOOL 2

COURSE CODE: CSA5113

COURSE NAME: Cryptography and Network Security

COURSE OUTCOME COVERED

CO4: *Implement best security practices for IP, email, and web service using PGP, S/MIME for enhancing email Security.CO (BL3, BL6)*

Assessment Tool Weightage: 20%

QUESTIONS: 5 TOTAL MARKS: 50

Annexure A

Industry Problem-Solving Task

Code of Conduct:

I DINDU PUJITHA(192373037) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student: D PUJITHA

Annexure A

Industry Problem-Solving Task

1. A multinational enterprise is deploying IPSec to secure communication between its branch offices over the public internet. Analyze how Authentication Header (AH) and Encapsulating Security Payload (ESP) should be configured to ensure both integrity and confidentiality across different types of traffic.

Tasks:

- A. Identify which traffic requires AH, ESP, or both**
- B. Design packet flow with appropriate IPSec
modes(transport/tunnel)**
- C. Justify protocol selection for different data types**
- D. Evaluate performance vs security trade-offs**

Answer:

A. Identify which traffic requires AH, ESP, or both

Traffic Type	Recommended Protocol	Reason
Financial transactions	ESP	Requires confidentiality, integrity, and authentication.
Employee credentials	ESP	Credentials and authentication information must be protected from disclosure.
Internal business documents	ESP	Sensitive information requires encryption and integrity protection.
Voice/video traffic	ESP	Protects sensitive

		communication; performance should be optimized with suitable algorithms and hardware acceleration.
Non-confidential traffic requiring integrity only	AH or authenticated ESP	Confidentiality may not be necessary; authenticated ESP is generally preferred in modern deployments.
General branch-to-branch traffic	ESP	Provides comprehensive protection for normal VPN traffic.

AH authenticates and protects the integrity of IP packets but does not encrypt the payload. ESP can provide confidentiality as well as integrity, authentication, and anti-replay protection. Using both AH and ESP is generally unnecessary when authenticated ESP already satisfies the required services.

B. Design packet flow with appropriate IPSec modes

For branch-to-branch VPN communication, tunnel mode should normally be used at the IPSec gateways. The original IP packet is protected and encapsulated inside a new IP packet.

Packet flow: Branch A host → Branch A IPSec gateway → ESP tunnel across the public Internet → Branch B IPSec gateway → Branch B host.

In tunnel mode, the original IP header and payload are encapsulated and protected. In transport mode, the original IP header remains visible while the payload is protected. Transport mode is more appropriate for direct host-to-host IPSec communication, whereas tunnel mode is preferred for network-to-network VPNs.

C. Justify protocol selection for different data types

- Highly sensitive financial data: use ESP with strong encryption and integrity protection.

- Employee authentication information: use ESP because confidentiality and integrity are important.
- Voice and video: use ESP with efficient cryptographic algorithms and appropriate QoS configuration.
- Non-confidential traffic that only needs authentication and integrity: AH can be considered, although authenticated ESP is normally preferable.
- Branch-to-branch traffic: use ESP tunnel mode to protect the complete original IP packet.

D. Evaluate performance vs security trade-offs

Option	Performance	Security
AH	Lower overhead because it does not encrypt	Integrity and authentication, but no confidentiality
ESP with authentication	Moderate overhead	Integrity, authentication, and anti-replay
ESP with encryption and authentication	Higher CPU and packet overhead	Strong confidentiality, integrity, authentication, and anti-replay
ESP tunnel mode	Higher overhead than transport mode	Strong protection for network-to-network VPNs

Encryption adds processing and packet overhead. However, modern VPN gateways commonly support hardware cryptographic acceleration. The recommended balance is ESP tunnel mode with strong authenticated encryption and automated IKE-based key management.

Recommendation: Deploy ESP in tunnel mode as the standard branch-to-branch VPN mechanism, with IKEv2 for automated key establishment and rekeying. AH should be reserved for specific legacy or integrity-only requirements.

2. An organization faces frequent key management issues in its IPSec implementation, leading to expired or mismatched keys. Propose a solution to efficiently manage Security Associations (SA) and automate key exchange in a scalable enterprise environment.

Tasks:

- A. Analyze current SA lifecycle issues**
- B. Design an automated key management mechanism (e.g., IKE-based)**
- C. Propose a strategy for key renewal and revocation**
- D. Evaluate scalability and fault tolerance**

Answer:

A. Analyze current SA lifecycle issues

- Keys may expire on one endpoint before the other endpoint updates them.
- Encryption or integrity parameters may be configured differently on peers.
- Manual configuration increases the probability of human error.
- Large numbers of SAs are difficult to monitor manually.
- Manual key rotation is slow and can cause service interruptions.
- Compromised keys may remain active if revocation is not performed quickly.
- Lack of centralized monitoring can delay detection of failed or expired SAs.

B. Design an automated key management mechanism (IKE-based)

Use IKEv2 to authenticate IPSec peers, negotiate security parameters, perform a secure key exchange, establish SAs, and automatically rekey them. The process is:

- VPN gateway A contacts VPN gateway B using IKEv2.
- The peers authenticate using suitable credentials such as digital certificates or pre-shared keys, according to the enterprise security policy.

- The peers negotiate cryptographic algorithms and security parameters.
- A secure key exchange establishes shared secret material.
- IPSec Child SAs are created for protected traffic.
- The gateways automatically monitor SA lifetime and initiate rekeying before expiration.

C. Strategy for key renewal and revocation

Rekeying should occur before an SA reaches its lifetime limit. Both time-based and, where appropriate, data-volume-based limits can be used. New keys should be established before old SAs are removed so that communication continues without unnecessary interruption.

- Automatically rekey SAs before expiration.
- Delete obsolete SAs after successful rekeying.
- Immediately disable an affected peer when compromise is suspected.
- Terminate active SAs associated with a compromised credential.
- Revoke compromised certificates or credentials.
- Generate fresh key material and re-establish the secure connection.
- Maintain audit logs of SA creation, renewal, and deletion.

D. Evaluate scalability and fault tolerance

- Use centralized VPN management and monitoring for large numbers of sites.
- Use redundant VPN gateways to avoid a single point of failure.
- Synchronize appropriate configuration and operational state between redundant gateways.
- Monitor SA status and alert administrators about approaching expiration or negotiation failures.
- Use multiple authentication or supporting infrastructure components where required.
- Maintain tested backup and disaster-recovery procedures.

Recommendation: IKEv2 with automated SA establishment and rekeying, centralized monitoring, and redundant VPN gateways is substantially more scalable and reliable than manual key management.

3. A financial services company needs to implement secure email communication for sensitive transactions. Evaluate and recommend between Pretty Good Privacy (PGP) and S/MIME based on usability, scalability, and enterprise integration requirements.

Tasks:

A. Compare PGP and S/MIME in real-world deployment scenarios

B. Analyze key management and trust models

C. Recommend a solution with justification

D. Design a high-level implementation workflow

Answer:

A. Compare PGP and S/MIME in real-world deployment scenarios

Feature	PGP	S/MIME
Encryption	Yes	Yes
Digital signatures	Yes	Yes
Trust model	Traditionally Web of Trust	Certificate Authority / PKI
Key management	More user-oriented and decentralized	More centrally managed
Scalability	More difficult for large centralized environments	Strong enterprise scalability
Enterprise integration	Depends on software and deployment	Strong integration with many enterprise mail systems
Administration	More user involvement	Centralized certificate lifecycle management

PGP provides flexibility and user control, but a large enterprise can find decentralized key verification and lifecycle management difficult. S/MIME uses X.509 certificates and

a PKI hierarchy, allowing the organization to manage identity, certificates, trust, and revocation centrally.

B. Analyze key management and trust models

PGP traditionally uses a Web of Trust in which users validate and sign other users' public keys. This decentralized model provides flexibility but can be operationally complex at enterprise scale.

S/MIME uses certificates issued through a trusted CA hierarchy. The organization can establish policies for certificate issuance, renewal, revocation, trust stores, and identity verification. This centralized model is generally easier to audit and manage in a corporate environment.

C. Recommend a solution with justification

Recommendation: S/MIME is the more suitable choice for a corporate financial email system when centralized identity, certificate lifecycle management, enterprise integration, and scalability are priorities.

- Centralized certificate management.
- Strong identity binding through organizational PKI.
- Support for encryption and digital signatures.
- Structured certificate renewal and revocation.
- Better suitability for large numbers of employees and managed devices.
- Easier integration with enterprise email and directory infrastructure.

PGP remains appropriate where decentralized trust, user-controlled keys, or OpenPGP-specific interoperability is a major requirement.

D. High-level implementation workflow

Employee identity verification → Certificate Authority issues certificate → Certificate and private key are installed securely → User composes email → Email is digitally signed and/or encrypted → Recipient receives message → Recipient validates the certificate and trust chain → Recipient verifies the signature and/or decrypts the message.

4. A company's email system is experiencing a rise in phishing and spam attacks despite basic filtering mechanisms. Analyze the weaknesses in the current system and propose an advanced spam detection strategy using email headers and content analysis.

Tasks:

A. Identify limitations of existing filtering techniques

B. Analyze email headers for spoofing indicators

C. Design an improved detection model (rule-based or ML-based) D. Evaluate effectiveness and false positive handling

Answer:

A. Identify limitations of existing filtering techniques

- Simple keyword rules can be bypassed by changing wording or using images.
- Static sender blocklists become outdated as attackers change addresses and infrastructure.
- Spoofed sender addresses can make malicious messages appear legitimate.
- URL shorteners and obfuscated links can hide suspicious destinations.
- Rules that are too aggressive may incorrectly block legitimate email.
- Traditional filters may not adapt quickly to new phishing campaigns.

B. Analyze email headers for spoofing indicators

- From: shows the apparent sender but should not be treated as sufficient proof of identity.
- Return-Path: can reveal differences between the visible sender and envelope sender.
- Received headers: can help trace the message path and identify unusual sending infrastructure.
- SPF: checks whether the sending server is authorized for the domain.
- DKIM: validates a cryptographic signature associated with the sending domain.
- DMARC: evaluates domain alignment and SPF/DKIM results and can support enforcement policies.

Header authentication results should be considered together rather than relying on a single indicator. A mismatch or failed authentication result can increase the risk score, but legitimate forwarding and mailing-list behavior should also be considered to avoid false positives.

C. Design an improved detection model

A hybrid detection architecture is recommended:

Incoming Email → Header and Authentication Analysis → Sender/IP/Domain Reputation → URL and Attachment Analysis → Content Feature Extraction → Machine-Learning Classifier → Risk Score → Inbox, Warning, or Quarantine.

- Header features: SPF, DKIM, DMARC, sender reputation, Received-header anomalies, and domain characteristics.
- Content features: suspicious phrases, urgency language, number and type of links, HTML characteristics, and attachment indicators.
- Possible ML models: Naive Bayes, Random Forest, Support Vector Machine, or neural-network-based classifiers.
- Use a risk score rather than a single yes/no rule so uncertain messages can be reviewed.

D. Evaluate effectiveness and false positive handling

Risk Level	Recommended Action
Low	Deliver to inbox
Medium	Deliver with warning or send for additional review
High	Quarantine for administrator/user review
Confirmed malicious/spam	Block or place in spam according to policy

To minimize false positives, combine multiple signals, maintain carefully controlled trusted-sender information, allow users or administrators to report misclassified messages, retrain models with recent examples, and monitor precision, recall, and false-positive rates. Quarantine is preferable to immediate deletion for uncertain cases.

Recommendation: Use a hybrid header, content, reputation, and machine-learning approach because it can adapt better to changing phishing and spam patterns than static keyword filtering alone.

5. During a security audit, it is found that encrypted email messages are vulnerable due to improper certificate handling in S/MIME. Diagnose the possible issues and recommend best practices to ensure secure certificate management and trust validation.

Tasks:

- A. Identify potential certificate-related vulnerabilities**
- B. Analyze trust chain and validation process**
- C. Propose secure certificate storage and management practices**
- D. Recommend improvements for user awareness and system configuration**

Answer:

A. Identify potential certificate-related vulnerabilities

- Expired certificates may cause validation failures or unsafe workarounds.
- Revoked certificates may continue to be trusted if revocation status is not checked.
- Untrusted or incorrectly configured CA certificates may allow invalid identities to be accepted.
- The certificate may not correctly match the email identity.
- Weak or obsolete cryptographic algorithms may reduce security.
- Private keys may be stored without adequate protection.
- Private keys must not be shared between users.
- Compromised certificates or private keys may remain active if incident procedures are inadequate.
- Users may bypass certificate warnings or trust errors.

B. Analyze trust chain and validation process

A typical S/MIME certificate chain is Root CA → Intermediate CA → User Certificate.

The recipient's system should validate the chain to a trusted root and verify that each certificate is valid and properly signed.

- Verify the certificate signature and chain.
- Verify that the certificate is within its validity period.
- Confirm that the root CA is trusted.
- Check the certificate's intended key usage and email identity.
- Check revocation status using the organization's supported mechanisms.
- Reject inappropriate or weak cryptographic algorithms according to policy.

C. Propose secure certificate storage and management practices

- Protect private keys using strong access controls and encryption at rest.
- Prefer hardware-backed key protection where practical for high-value users or systems.
- Never share private keys between employees.
- Maintain a central inventory of certificates and expiration dates.
- Automate renewal before certificates expire.
- Maintain clear procedures for certificate revocation and replacement.
- Restrict CA and certificate-management administration using role-based access controls.
- Maintain audit logs for issuance, renewal, revocation, and administrative changes.
- Maintain secure backups and recovery procedures for keys and certificates where organizational policy requires them.

D. Recommend improvements for user awareness and system configuration

- Train users not to ignore or bypass certificate warnings.
- Teach users how to recognize unexpected certificate or identity changes.
- Require users to report suspected private-key compromise immediately.
- Configure enterprise trust stores centrally and consistently.
- Disable weak or obsolete cryptographic algorithms.

- Enable appropriate certificate revocation checking.
- Enforce certificate identity and validity checks.
- Automate certificate renewal and monitor expiration.
- Maintain an incident-response procedure for compromised certificates.

Recommendation: Establish centralized S/MIME certificate lifecycle management, strict trust-chain validation, secure private-key storage, automated renewal and revocation procedures, and continuous user awareness training.

Overall Recommendations

Problem Area	Recommended Solution
Branch-to-branch IPSec VPN	ESP + Tunnel Mode + IKEv2
IPSec key management	Automated IKEv2 SA establishment and rekeying
Corporate financial email	S/MIME with managed enterprise PKI
Spam and phishing	Hybrid header + content + reputation + ML detection
S/MIME certificate security	Centralized certificate lifecycle management and strict trust validation

These recommendations provide a practical enterprise security architecture emphasizing confidentiality, integrity, authentication, scalable key management, secure email, adaptive threat detection, and strong certificate governance.

Assessment Question Source

The questions and task structure in this document are based on the uploaded CSA5113 Cryptography and Network Security Assessment Tool 2, Industry Problem-Solving Task. The source specifies five questions covering IPSec AH/ESP, IPSec Security Associations and IKE, PGP versus S/MIME, email spam/phishing detection, and S/MIME certificate management. filecite\turn0file0\L19-L38 filecite\turn0file0\L39-L66